AIORI 3 | CATEGORY: CYBERSECURITY | PS-019

A3-PS019-TC157

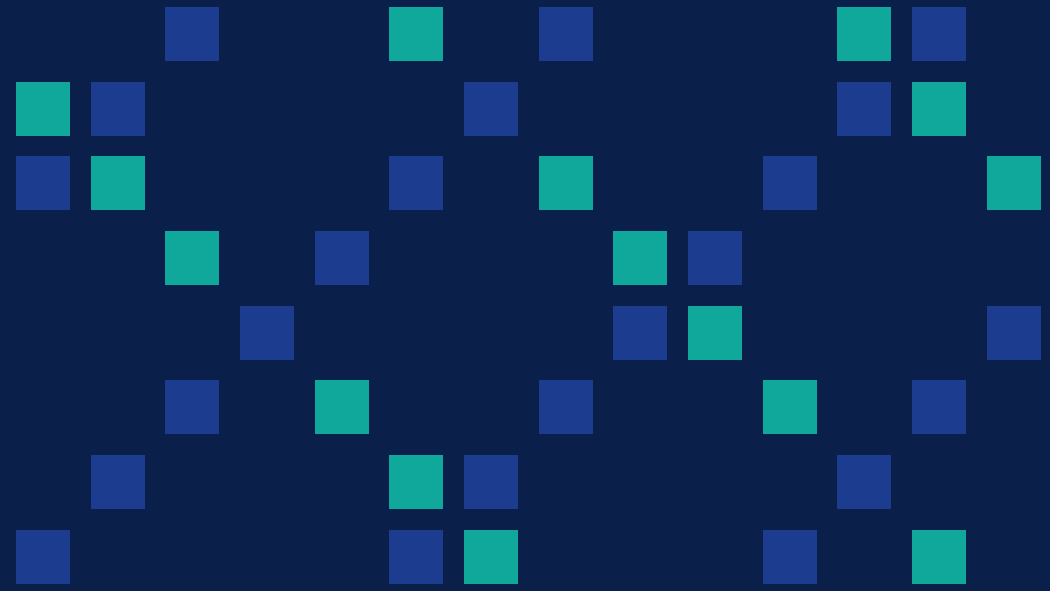
Personal-Data Discovery and Privacy Evidence Inventory

Daya

daya.bahuguna@gmail.com

AIORI Hackathon 3

October 14, 2026



Problem Description

- **Shadow PII:** personal data piles up across unindexed SQL tables and spreadsheets with little or no documentation.
- **No inventory:** owners cannot say which fields hold names, contact details, government IDs or financial data.
- **Broken linkage:** fields are rarely tied to a declared business purpose or a retention schedule.
- **Manual audits don't scale:** column-by-column review is slow, inconsistent and hard to repeat.
- **Over-claiming risk:** tools that auto-decide "compliance" go beyond what technical evidence can support.

What is needed

1. **DISCOVER**
   candidate PII fields in CSV + SQL
2. **LINK**
   each field to purpose + retention
3. **FLAG**
   missing metadata and evidence gaps
4. **MEASURE**
   per-class precision and recall

Boundary: technical evidence only. No automatic lawful-basis determination, no legal-compliance decision, no universal data-flow inference. Humans own the interpretation.

Background

- **India's DPDP Act, 2023** [1][2] puts duties on organisations that process digital personal data, including purpose-bound use and limited storage.
- **Data governance** starts with knowing what you hold: a data inventory comes before any control, policy or audit.
- **Comparable records:** GDPR Art. 30 [5] and ISO/IEC 27701 [11] also expect documented processing, purposes and retention.
- **PII guidance** such as NIST SP 800-122 [3] and ISO/IEC 29100 [4] treats identification of PII as the first step in protecting it.
- **The practical gap:** legacy CSV exports and SQL tables rarely carry purpose or retention metadata.

This tool: TECHNICAL EVIDENCE

Which fields *look like* personal data, with the rule, score and sample that triggered each match; which declared purpose/retention is attached; what is missing.

Out of scope: LEGAL INTERPRETATION

Lawful basis, consent validity, compliance verdicts and cross-system data-flow conclusions are left to the human reviewer and legal counsel.

Literature & RFC Review

Approach	Reference / standard	What it gives us	Limitation we address
Pattern matching	RFC 5322 email [6]; ITU-T E.164 phone [7]; Python `re` [12]	Precise, explainable detectors for structured identifiers	Context-blind: digits in an order ID can look like a phone number
Checksum validation	Luhn / ISO/IEC 7812 [8]; Verhoeff (Aadhaar-style IDs) [9]	Cuts false positives on card and ID numbers	Only helps classes that carry a check digit
Schema inspection	`INFORMATION_SCHEMA`; SQLAlchemy Inspector [13]	Column names, types and keys without scanning every row	Names can be misleading (`col7`) so values still need checking
NER / ML detectors	Microsoft Presidio [10]	Handles free text and names well	Heavier, harder to explain, tuned for text, not tabular columns
Frameworks	NIST SP 800-122 [3]; ISO/IEC 29100 [4]; ISO/IEC 27701 [11]	Define PII, inventory and purpose/retention concepts	Describe *what* to record, not how to find it in files

Our position

Combine **column-name hints + value patterns + checksums** in a configurable, explainable rule engine, then attach declared purpose/retention and report the gaps.

Proposed Solution

5 DATA CLASSES (proposed set; fully configurable in rules.yaml)

Person Name	Email	Phone	Government ID	Financial
full / first / last	user@domain	E.164, Indian mobile	Aadhaar-style, PAN	card (Luhn), account no.

1 Parse sources

Stream CSV in chunks; read SQL schema + sampled rows over a read-only connection.

2 Detect candidates

Score each column from name hints, regex hit-rate and checksum pass-rate; threshold set per class.

3 Map metadata

Join each field to declared purpose and retention (data dictionary / register).

4 Report

Evidence inventory, missing-metadata gap report, per-class precision/recall.

PSEUDOCODE SNIPPET

```
load rules.yaml, purpose_retention.csv
for source in csv_files + sql_tables:
  for col in source.columns:
    sample = stream(col, n=500)
    score = w1 * name_hint(col.name)
          + w2 * pattern_hit_rate(sample)
          + w3 * checksum_pass_rate(sample)
    if score >= threshold[cls]:
      meta = lookup(source, col)
      inventory.add(col, cls, score, evidence)
      if not meta.purpose or not meta.retention:
        gaps.add(col, missing_fields(meta))
report(inventory, gaps)
precision_recall(inventory, labelled_set)
```

Optimization Proposed

Regex caching

Compile every rule once at load and reuse it across all columns and files instead of recompiling per cell.

Parallel DB indexing

Inspect tables concurrently (thread pool, one read-only connection each) and cache schema results.

Sampling + early exit

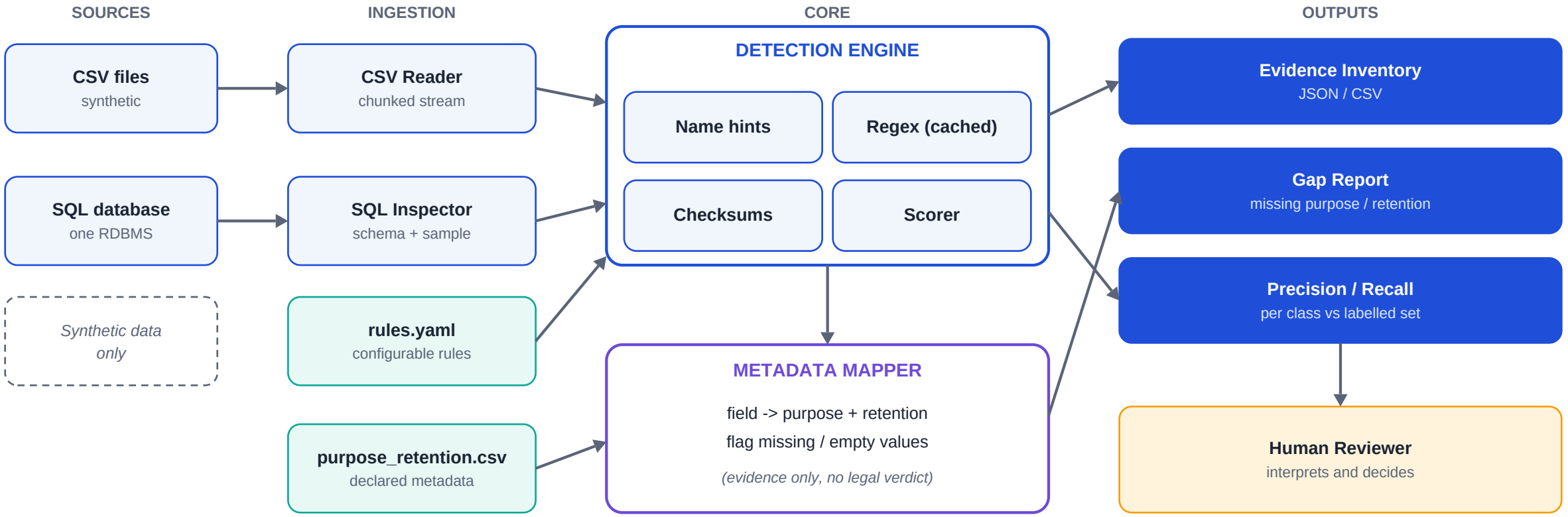
Stream CSV in chunks, test a bounded sample per column and stop once a class decision is stable.

Aspect	Before (naive scanner)	After (optimized design)	Target metric*
Rule compilation	Regex compiled per cell	Compiled once, cached per rule set	Fewer than 1 compile per rule per run
Column scan	Every row of every column	Bounded sample + early exit	At least 5x fewer values tested
SQL inspection	Tables scanned one by one	Parallel per-table workers + schema cache	Near-linear speed-up with workers
Memory use	Whole CSV loaded in memory	Chunked streaming	Constant memory per file
Explainability	Match / no match only	Score + rule + sample stored as evidence	Every candidate field has evidence

**Design targets, not measured results. They will be validated by a benchmark on the synthetic dataset before the final report.*

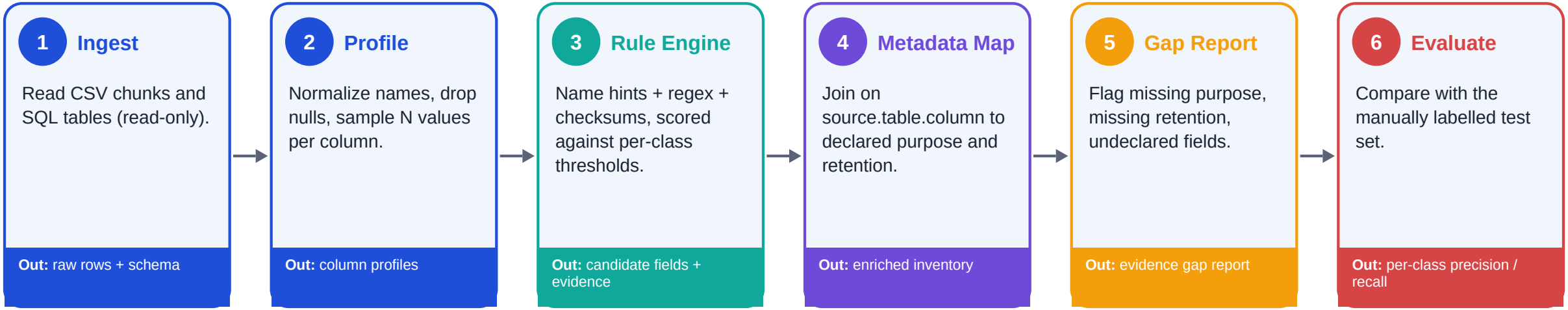
Note: optimizations change speed and cost only. They must not change detection results; regression-checked against the labelled test set.

Solution Architecture & Design



Boundary: technical evidence only. No automatic lawful-basis determination, no legal-compliance decision, no universal data-flow inference. Humans own the interpretation.

Data Flow Diagram

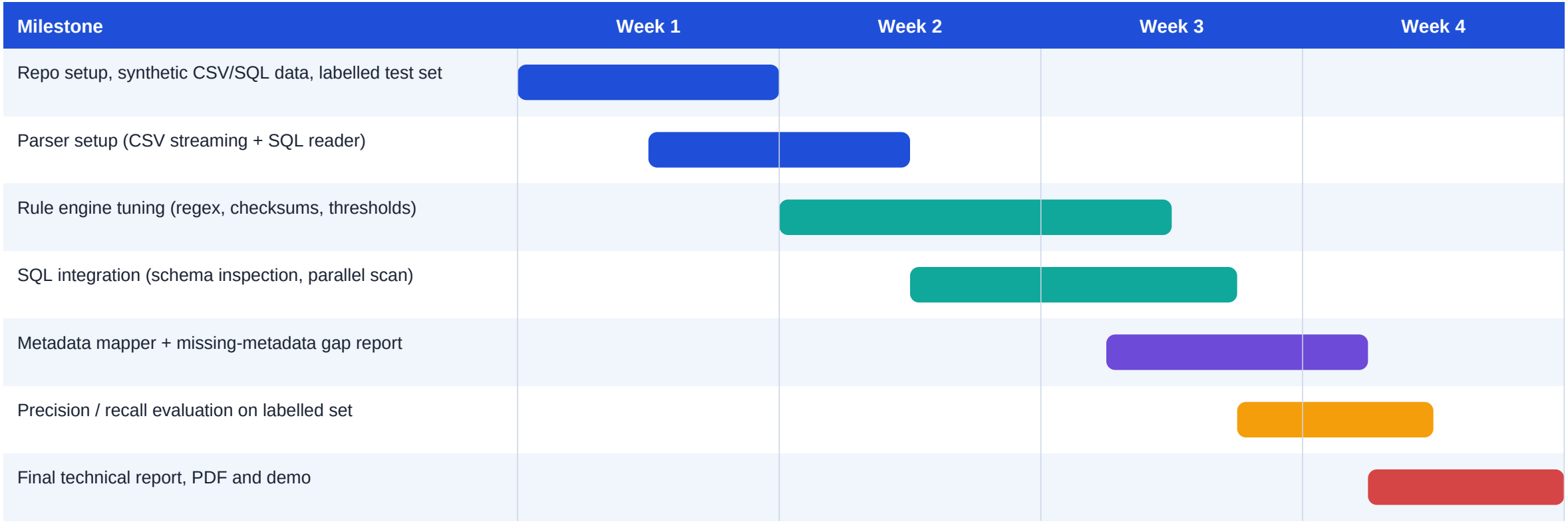


Controls along the pipeline

- **Configurable:** rules.yaml sets patterns, thresholds and class list; metadata file supplies purpose/retention.
- **Traceable:** each inventory row stores the matching rule, score and a masked sample as evidence.
- **Human review checkpoint:** the inventory and gap report are inputs for a reviewer. The tool never decides lawfulness.

Boundary: technical evidence only. No automatic lawful-basis determination, no legal-compliance decision, no universal data-flow inference. Humans own the interpretation.

Deployment Timeline



Indicative plan; weeks are compressed or stretched to match the hackathon schedule. Methodology: iterative, evaluate after every milestone.

M1 - Working scanner

CSV + SQL parsed; first rules firing.

M2 - Linked inventory

Metadata mapped, gaps reported.

M3 - Evaluated demo

Per-class P/R + final report.

Bibliography

[1] Government of India. *The Digital Personal Data Protection Act, 2023* (Act No. 22 of 2023).

[2] MeitY. *Data Protection Framework*. https://www.meity.gov.in/data-protection-framework

[3] E. McCallister, T. Grance, K. Scarfone. *Guide to Protecting the Confidentiality of PII*, NIST SP 800-122, 2010.

[4] ISO/IEC 29100:2011. *Information technology - Security techniques - Privacy framework*.

[5] European Union. *Regulation (EU) 2016/679 (GDPR)*, Arts. 5 and 30.

[6] P. Resnick (Ed.). *Internet Message Format*, RFC 5322, IETF, 2008.

[7] ITU-T. *The international public telecommunication numbering plan*, Recommendation E.164, 2010.

[8] ISO/IEC 7812-1. *Identification cards - Identification of issuers*; H. P. Luhn, US Patent 2,950,048, 1960.

[9] J. Verhoeff. *Error Detecting Decimal Codes*, Mathematical Centre Tract 29, Amsterdam, 1969.

[10] Microsoft. *Presidio: Data Protection and De-identification SDK* (documentation).

[11] ISO/IEC 27701:2019. *Privacy information management systems - Requirements and guidelines*.

[12] Python Software Foundation. *re - Regular expression operations*, Python documentation.

[13] SQLAlchemy. *Runtime Inspection API / Inspector*, SQLAlchemy documentation.

Thank You for Your Attention!

Questions and demo

Daya | daya.bahuguna@gmail.com

A3-PS019-TC157 | AIORI Hackathon 3 | October 14, 2026